

Wireshark

Análisis de la Captura Wireshark (Práctica 4)

- **¿Puedes localizar ClientHello?**
 - **Respuesta:** Sí, se encuentra en el **paquete 308**. Es enviado desde la IP del cliente (192.168.0.198) hacia la IP del servidor (192.168.0.196).
- **¿Qué versión de TLS se está utilizando?**
 - **Respuesta:** Tal y como indica la columna "Protocol" en los paquetes remarcados, se está utilizando **TLSv1.3** (la versión más moderna y segura).
- **¿Le sigue ServerHello?**
 - **Respuesta:** Sí. Tras un paquete de confirmación de red (el ACK del paquete 309), el servidor envía el **Server Hello** en el **paquete 310**.
- **¿Hay otros mensajes "lógicos" del protocolo TLS que han sido integrados en el mismo paquete TCP con el mensaje ServerHello?**
 - **Respuesta:** Sí. Mirando la columna "Info" del paquete 310, se puede observar que Wireshark ha agrupado tres mensajes lógicos en el mismo envío: Server Hello, Change Cipher Spec y datos cifrados (Application Data).
- **¿Detectas luego el mensaje ClientKeyExchange?**
 - **Respuesta (⚠ ¡La trampa del examen!): No se detecta ningún mensaje con ese nombre explícito. * Justificación para el profesor:** Como el navegador y el servidor han negociado usar **TLS 1.3**, el proceso de "apretón de manos" es diferente y mucho más rápido que en TLS 1.2. El intercambio de claves ya va incrustado en los mensajes iniciales y todo lo que sigue viaja completamente cifrado, por lo que Wireshark simplemente lo etiqueta de forma genérica como Application Data (paquetes 310, 311, 312).
- **¿Hay más mensajes del cliente integrados en el mismo paquete TCP?**
 - **Respuesta:** Sí. En el **paquete 311**, el cliente (origen 192.168.0.198) envía de forma integrada un mensaje Change Cipher Spec y un bloque de datos cifrados (Application Data).
- **¿Aparece finalmente el mensaje ChangeCipherSpec que envía el servidor?**
 - **Respuesta:** Sí aparece, pero no "finalmente". Aparece adelantado e integrado dentro del **paquete 310**, exactamente en la misma línea que el Server Hello.

NMAP

Para escanear la red usar target:

Ejemplo: www.epigijon.uniovi.es

Varias subredes

156.35.141.0/24 | Esto se le denomina CIDR

156.35.141-145.* | Donde * es el /24

Tipos de Perfil

- **Intense scan (Escaneo intenso):** El "todo en uno" rápido. Escanea los 1.000 puertos TCP más comunes, detecta el Sistema Operativo (SO), la versión de los servicios y lanza scripts de vulnerabilidades básicos. Es el que vas a usar el 90% de las veces en clase.
 - `nmap -T4 -A -v`
 - *El combo clásico:* -T4 para ir rápido (Aggressive timing) , -A para hacerlo todo (SO, versiones, scripts básicos) y -v para ver los resultados en vivo (Verbose).
- **Intense scan plus UDP:** Hace lo mismo que el anterior, pero además escanea puertos UDP (como DNS o DHCP). **Cuidado:** El tráfico UDP no orienta a conexión, por lo que este escaneo es *terriblemente lento*.
 - `nmap -sS -sU -T4 -A -v`
 - Añade -sU para forzar el escaneo de puertos UDP. El -sS fuerza el escaneo TCP SYN (más sigiloso que el TCP Connect completo).
- **Intense scan, all TCP ports:** Hace el análisis profundo, pero en lugar de mirar 1.000 puertos, revisa **los 65.535 puertos TCP posibles**. Tarda bastante más, pero no deja ningún rincón sin mirar.
 - `nmap -p 1-65535 -T4 -A -v`
 - El parámetro estrella es -p 1-65535. Obliga a mirar los más de 65.000 puertos en lugar de los 1.000 por defecto
- **Intense scan, no ping:** Hace el escaneo intenso, pero se salta la fase previa de comprobar si el equipo responde al comando *ping*. Ideal para cuando sabes que el servidor está encendido pero un cortafuegos te bloquea los paquetes ICMP de descubrimiento.
 - `nmap -T4 -A -v -Pn`
 - Añade -Pn (No Ping). Le prohíbe a Nmap enviar paquetes de descubrimiento previos. Asume que la máquina está encendida.
- **Ping scan:** El más básico. Solo pregunta "¿Hay alguien ahí?". No mira ningún puerto, solo busca equipos vivos en la red. Tarda segundos.
 - `nmap -sn`
 - Usa -sn (No port scan). Literalmente le dice a Nmap que se limite a buscar qué equipos están encendidos en la red sin intentar mirar sus puertos. (Nota: en versiones antiguas de Nmap esto se escribía -sP)

- **Quick scan (Escaneo rápido):** En lugar de mirar 1.000 puertos, escanea solo los 100 más populares. Superútil si tienes prisa y solo buscas servicios típicos (HTTP, FTP, SSH).
 - `nmap -T4 -F`
 - El parámetro clave es `-F` (Fast). Le dice a Nmap que reduzca la lista y solo escanee los 100 puertos TCP más comunes.
- **Quick scan plus:** Escanea esos 100 puertos populares muy rápido, pero le añade la detección de SO y versiones para darte más contexto.
 - `nmap -sV -T4 -O -F --version-light`
 - Combina rapidez (`-F`) con detección de Sistema Operativo (`-O`) y detección de servicios (`-sV`). El parámetro extra `--version-light` hace que la comprobación de los servicios sea menos exhaustiva para ahorrar tiempo.
- **Quick traceroute:** No busca puertos abiertos. Su única misión es trazar la ruta (los "saltos" por los routers intermedios) desde tu ordenador hasta el equipo objetivo.
 - `nmap -sn --traceroute`
 - No escanea puertos (`-sn`). Solo intenta averiguar el camino de routers por el que pasa tu paquete mediante `--traceroute`.
- **Regular scan (Escaneo regular):** Es el Nmap estándar y puro. Escanea los 1.000 puertos comunes sin ser agresivo, sin detectar versiones y sin SO.
 - `nmap`
 - Así de simple. No añade nada. Usa la velocidad normal (`-T3`) y solo mira los 1.000 puertos TCP por defecto.
- **Slow comprehensive scan (Escaneo completo lento):** El modo paranoico. Revisa los 65.535 puertos TCP, los puertos UDP, usa todos los scripts, detecta el SO y va **muy despacio** para evitar que los sistemas de seguridad (IDS/IPS) salten. En un entorno de red real puede tardar días en terminar.
 - `nmap -sS -sU -T4 -A -v -PE -PP -PS80,443 -PA3389 -PU40125 -PY -g 53 --script "default or (discovery and safe)"`
 - ¡El monstruo! Lanza escaneo TCP y UDP (`-sS -sU`), suplanta el puerto de origen para evadir firewalls simulando ser una consulta DNS (`-g 53`), y lanza docenas de "sondas" especiales (`-PE, -PP, -PS...`) para obligar a la máquina a responder.

Construcción de Comandos

VELOCIDAD

- **-T0 (Paranoid):** Extremadamente lenta. Envía paquetes con mucha separación de tiempo.
- **-T1 (Sneaky):** Muy lenta. Útil para evitar a los sistemas de detección de intrusiones (IDS).
- **-T2 (Polite):** Educada. Es improbable que interfiera con el sistema objetivo o sature la red.

- **-T3 (Normal):** Esta es la plantilla de temporización por defecto si no pones nada.
- **-T4 (Aggressive):** Produce resultados más rápidamente en redes locales que son fiables y rápidas.
- **-T5 (Insane):** Escaneo muy rápido y agresivo. Asume que estás en una red extraordinariamente rápida.

-A indica que se realice un "Aggressive scan"

-v "Verbose output"

-sn (no port scan) le indica a Nmap que no escanee los puertos de los hosts descubiertos

Topología de una red

Puertos abiertos	0-2	3-4	5-6	7-8	9 o más
Icono					

Detección de los host de una red

1- Fase de Descubrimiento de hosts usando Ping Scans

- Opciones:
 - **-Pn** (no ping) indica a Nmap que prescinda de la fase de descubrimiento Muy Lento porque escaneo todos los puertos.
 - **sn** : Tipico Ping Scan no escanea puertos al ser modo ICMP no requiere puerto
 - **-PE** = ICMP Echo Ping. Es la opción por defecto si no se especifican otras. Muchos hosts están configurados para no responder a paquetes ICMP por razones de seguridad.
 - **PP** = ICMP Timestamp Ping. Es otra opción basada en ICMP para intentar recibir una respuesta que no sea bloqueada por los cortafuegos.
 - **PS** = TCP SYN Ping. Envía un paquete SYN al objetivo y espera la respuesta. Este método puede ser útil para los sistemas que bloquean los pings estándar ICMP.
 - **PA** = TCP ACK Ping. Envía un paquete TCP ACK al objetivo, aunque no existe una conexión, y espera algún tipo de respuesta. Este método puede ser útil para los sistemas que bloquean los pings estándar ICMP.
 - **-sS** (Sondeo TCP SYN)

2- Análisis de cada uno de los hosts

Siguiente apartado del doc de Deteccion de SO y servicios

Otros comandos extra para detección de host:

-sS (**SYN**): Inicia la conexión pero la corta de golpe para no dejar rastro (sigiloso, es el estándar, requiere permisos de administrador).

-sT (**Connect**): Completa la conexión TCP entera (ruidoso, queda registrado en los logs del servidor objetivo, no requiere permisos especiales).

-sU (**UDP**): Escanea puertos de servicios que no usan TCP, como DNS o DHCP (terriblemente lento al no estar orientado a conexión).

-sN (**Null**): Envía un paquete "vacío" sin banderas TCP activadas (evade firewalls antiguos buscando provocar una respuesta de error).

-sF (**FIN**): Envía únicamente la bandera de "fin de conexión" (evade firewalls, pero es inútil contra sistemas Windows).

-sX (**Xmas**): Enciende las banderas FIN, PSH y URG iluminando el paquete "como un árbol de Navidad" (evade cortafuegos sin estado, también inútil contra Windows).

-sA (**ACK**): Finge enviar datos de una conexión que ya estaba establecida (no descubre puertos abiertos, **solo sirve para mapear las reglas del firewall**).

-sI <IP> (**Idle**): Utiliza un equipo tercero de la red como "zombie" para rebotar el tráfico (es un escaneo 100% anónimo para tu IP).

Detección del SO y servicios

El proceso de identificación del SO del objetivo y su versión, se denomina "**TCP/IP fingerprinting**"

- opción **-O** habilita la detección del SO de los hosts escaneado
 - **--osscan-guess**. Si Nmap no está seguro del SO, este parámetro le obliga a darte su mejor estimación con un porcentaje de probabilidad (ej. *Windows 10* - 95%).
- **-sV (Service Version)**: Activa la detección de versiones de los servicios que corren en los puertos abiertos.
 - *Variante de velocidad*: **--version-light**. Hace que la comprobación de versiones sea más rápida (pero menos precisa), ideal si vas mal de tiempo en el examen.
 - *Variante agresiva*: **--version-all**. Prueba absolutamente todas las sondas de Nmap para descubrir un servicio rebelde (muy lento).
 - **-sV -p 443 --script ssl-enum-ciphers** : para determinar la seguridad de SSL/TLS. : Lista el nivel de seguridad de cada versión de cifrado: A (mejor) a F (peor).
 - **nmap -p 443 --script ssl-cert** : Obtener información sobre el certificado que utiliza un servidor para trabajar con SSL/TLS

- **nmap -p 443 --script sslv2** : Para comprobar si el servidor, permite el uso de SSL V2.0
- **nmap -p 443 --script ssl-dh-params** : para comprobar si existe alguna vulnerabilidad en los conjuntos de cifrado que utilizan el algoritmo de Diffie-Hellman para acordar claves sobre un servidor de Uniovi
- **-A (Aggressive)**: Como recordatorio, este parámetro te incluye de golpe tanto el -O como el -sV (junto con scripts y traceroute).

Evasión del cortafuegos

- **-f (Fragmentación de paquetes)**: Divide la cabecera TCP en trozos muy pequeños (fragmentos de 8 bytes).
 - *Variante*: -ff (fragmentos de 16 bytes) o --mtu <número> para especificar un tamaño a medida (debe ser múltiplo de 8).
- **-D <IP1,IP2,ME> (Decoys / Señuelos)**: Oculta tu escaneo entre un mar de direcciones IP falsas.
 - *Ejemplo*: nmap -D 10.0.0.5,10.0.0.6,ME 192.168.1.100. El servidor creará que le están atacando 3 máquinas a la vez.
- **-g <puerto> o --source-port <puerto> (Falsificación de puerto origen)**: Hace creer al cortafuegos que tu escaneo proviene de un puerto "de confianza".
 - *Los clásicos*: -g 53 (simula ser tráfico DNS) o -g 20 (simula ser tráfico de datos FTP).
 - *Ejemplo* : nmap -sn -g 20 192.168.0.0/24
 - **Puerto 53 (DNS)**: El principal. Engaña al cortafuegos simulando ser respuestas inofensivas de resolución de dominios.
 - **Puerto 20 (FTP Data)**: El clásico de examen. Finge ser una transferencia de archivos de un servidor FTP en modo activo.
 - **Puertos 80 y 443 (HTTP/HTTPS)**: Se camufla como tráfico de respuestas de navegación web normal.
 - **Puerto 123 (NTP)**: Simula ser tráfico de sincronización del reloj del sistema.
 - **Puerto 67 (DHCP)**: Finge ser tráfico interno de asignación de direcciones IP.x
- **--data-length <número> (Añadir basura)**: Añade datos aleatorios al final de los paquetes.
 - *Ejemplo*: --data-length 25. Por defecto, Nmap envía paquetes con tamaños muy específicos y predecibles. Esto cambia el tamaño para despistar.
- **--spoof-mac <dirección> (Falsificación de MAC)**: Cambia tu dirección MAC temporalmente. Puedes poner una MAC inventada, o decirle a Nmap que genere una de un fabricante concreto (ej. --spoof-mac Apple).